ISO/IEC 27001:2022 · 含 Amd 1:2024

# ISMS 條款對照台使用指南

從工作情境到 SoA 的 ISO 27001 導入工具

從第一次導入到每年維運：依你對 ISMS 的熟悉程度，選一條路線開始。

A

**第一次導入**

剛接下 ISMS 任務，不確定從哪裡開始。照著總覽的「下一步建議」一步一步做。

B

**手上已有資料**

已經有 SoA 或風險評鑑表 Excel，想檢查有沒有缺口、轉成可持續維護的專案。

C

**年度維運與顧問**

已通過驗證或同時輔導多家公司。建立新年度、與去年比較、追蹤改善事項。

# 先選一條路線

三條路線用的是同一套工具，差別在起點。不確定的話從 A 開始；B、C 會用到 A 介紹過的畫面。

### A 第一次導入

IT 或行政人員第一次負責 ISMS

- 建立專案、確認風險準則
- 從常見情境新增風險
- 完成適用性聲明（SoA）
- 內部稽核後追蹤改善

第 5–10 頁

### B 手上已有資料

已有 Excel 版 SoA、風險評鑑表

- 從 Excel 匯入並看匯入報告
- 依下一步建議補齊缺口
- 匯出含文件管制的 Excel

第 11–12 頁

### C 年度維運與顧問

已驗證、或同時管理多家公司

- 建立新年度、與去年比較
- 產出管理審查輸入資料
- 多專案與備份管理

第 13–14 頁

## 使用前要知道的三件事

**資料只存在你的瀏覽器**
不需註冊、不會上傳。換電腦或清除瀏覽資料前，請到「專案管理」匯出專案檔（JSON）。修改累積較多時，畫面上方會提醒備份。

**只提示，不代替判定**
產業建議、連動檢查與下一步建議都只標出問題。適用與否仍依你的風險評鑑結果決定，按下按鈕才會修改，而且可以復原。

**先看範例也可以**
首頁下方有 8 個產業 × 3 個導入階段的虛構公司。預覽時的修改不會儲存，覺得合適可以「以此範例建立我的專案」。

## 九個分頁各做什麼

| 分頁 | 用途 | 對應條款 |
|---|---|---|
| 首頁 | 建立新專案、匯入 Excel 或專案檔、預覽範例 | — |
| 總覽 | 導入進度（8 步）、下一步建議、熱圖與負責人工作量 | 全部 |
| 案例搜尋 | 用日常說法查條款，例如「同事離職」「廠商遠端」 | 附錄 A |
| 風險評鑑 | 風險準則、風險登錄、處理計畫、與 SoA 的連動檢查 | 6.1.2、6.1.3 |
| 附錄 A 確認 | 93 項控制措施的適用性、理由、執行狀態、負責人、證據 | 6.1.3 d（SoA） |
| 條款 4–10 | 管理系統本文條款的執行狀態 | 4–10 |
| 改善追蹤 | 稽核發現、管理審查決議、矯正措施，追蹤到確認有效 | 9.2、9.3、10 |
| 文件範本 | 32 份手冊、政策、程序、表單、紀錄範本 | 7.5 |
| 專案管理 | 專案設定、建立新年度、與去年比較、文件管制、備份 | 7.5、9.3 |

# 工具裡的導入進度：8 個步驟

總覽最上方的步驟圖示依專案資料自動判斷完成與否。順序可以交錯，不必等前一步全部做完。




| 步 | 要做的事 | 怎樣算完成 |
|---|---|---|
| 1 | 決定驗證範圍與業務特性 | 填了驗證範圍，並選擇產業或業務特性 |
| 2 | 訂定風險評鑑準則 | 在「調整準則」按過「確認並套用」（新專案帶入的預設值不算） |
| 3 | 識別與評估風險 | 至少一個風險，且每個都有可能性與衝擊分數、沒有待重新評估 |
| 4 | 決定風險處理與適用性 | 93 項都已判定、不適用的都有理由、風險與 SoA 沒有衝突 |
| 5 | 核准 SoA 與處理計畫 | 文件管制狀態為「已核准」，需核准的殘餘風險都已由擁有者核准 |
| 6 | 落實控制措施 | 適用的控制措施都已實施或已驗證 |
| 7 | 條款、內部稽核、管理審查 | 條款 4–10 都已實施或已驗證 |
| 8 | 改善事項結案 | 內部稽核已完成，且改善事項都「已確認有效」 |

## 名詞小辭典

**適用性聲明（SoA）**
列出附錄 A 每一項控制措施適用或不適用、理由與實施情形。驗證稽核必看。

**固有風險／殘餘風險**
固有是目前的風險；殘餘是採取處理措施之後預期剩下的風險。

**風險 vs. 事件**
風險是「可能發生」的事；已發生的叫資安事件，登錄在改善追蹤，並作為評估可能性的依據。

**管理審查（9.3）**
管理階層定期檢討 ISMS 的會議。年度比較可以產出會議的輸入資料。

**風險評鑑準則**
可能性 × 衝擊的分數，到幾分可以接受、幾分要處理。需經管理階層核准。

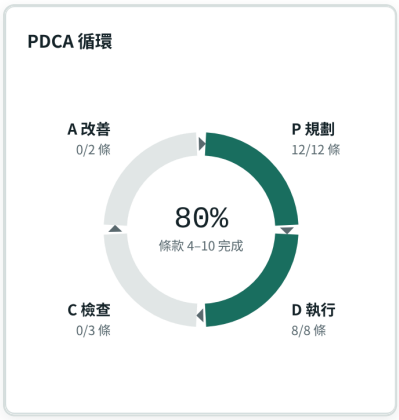
**風險擁有者**
對這個風險負責、核准處理方式與殘餘風險的人，通常是業務主管。

**不符合 vs. 觀察**
不符合是未達到要求，須原因分析與矯正措施（10.2）；觀察是可能演變成問題的提醒。

**Amd 1:2024**
2024 年增修：條款 4.1 要判斷氣候變遷是否為相關議題，4.2 註記利害關係者可能有氣候要求。

# 三個實用管理模型，在工具的哪裡

導入與維運 ISMS 最常用的三個模型：PDCA、風險管理流程與產品生命週期。在工具裡它們都是「活的圖」：依專案資料顯示進度，點一下就能看說明或篩選出要處理的項目。




## 1　PDCA 循環（總覽）

條款 4–10 依 Plan、Do、Check、Act 分組，圓環顯示各階段的完成情形，點一段可看對應條款。

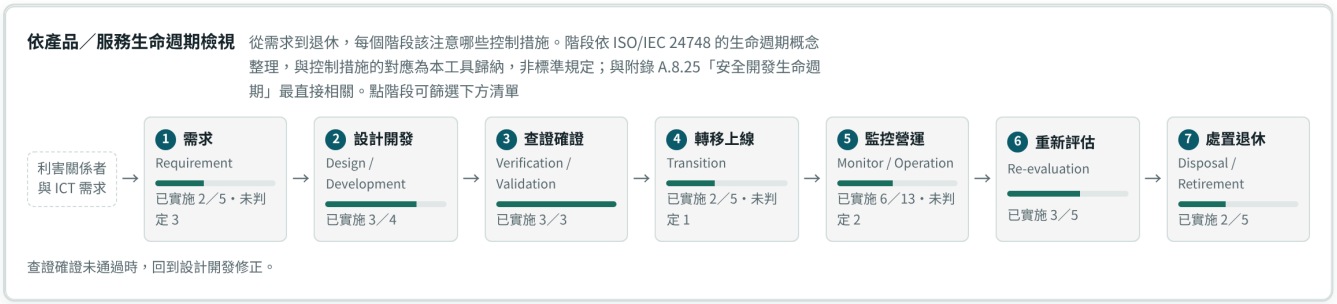
工具也把 Act 接回下一輪 Plan：改善追蹤記錄稽核發現與矯正措施；建立新年度時，未結案事項會帶入，年度比較則成為下次管理審查的輸入。

## 2　風險管理流程（風險評鑑頁上方）




依 ISO/IEC 27005、ISO 31000：建立全景 → 〔風險評鑑：識別 → 分析 → 評估〕 → 〔風險處理：處理 → 接受〕，下方是貫穿每一步的「溝通與諮詢」「記錄與報告」「監督與審查」。綠色打勾是已完成，紅色是有風險卡在這一步。點任一步驟會顯示說明與可直接做的動作，有待處理的風險時同時篩選下方清單。

## 3　產品／服務生命週期（附錄 A 頁上方）




依 ISO/IEC 24748 的生命週期概念整理（階段與控制措施的對應為本工具歸納，非標準規定；最直接相關的是 A.8.25 安全開發生命週期）：需求 → 設計開發 → 查證確證 → 轉移上線 → 監控營運 → 重新評估 → 處置退休。每個階段列出相關控制措施與實施進度；查證確證未通過時回到設計開發。

**什麼時候用生命週期檢視？**　IT 人員問「新系統要上線，該注意哪些控制措施？」「舊伺服器要報廢，要留什麼紀錄？」時，點對應的階段就能列出來。它只是另一種分組方式，不會改變適用性判定。

# 建立專案，讓總覽帶路

一個專案代表一家公司或一次驗證。建好之後，大部分時間只要看總覽的「下一步建議」。




首頁：左邊直接填表建立專案；右邊可匯入既有資料或下載文件範本。

1. **填專案名稱與驗證範圍**
   範圍寫成一句話：哪些業務、在哪裡、用哪些系統。之後可在「專案管理」修改。
2. **展開「產業與業務特性」（選填）**
   選產業會帶入常見特性，附錄 A 會用紫色底線標出建議優先關注的項目，並列出相關法規。
3. **選附錄 A 起始狀態**
   第一次導入選「全部未決定」，逐項判定；已經很熟悉的可以選「預設全部適用」，再挑出要排除的項目。
4. **按「建立專案」**
   會直接進入總覽。

**不知道怎麼填？**
先到首頁下方預覽同產業的範例公司，看「驗證稽核前」階段長什麼樣子，再回來建立自己的專案。

# 看懂總覽：進度與下一步

上半部是 8 步的導入進度，下半部是依急迫程度排序的待辦。每一項都有按鈕，點了就到對應的畫面。




新專案的總覽：目前在第 2 步，第一項建議是確認風險評鑑準則。

## 導入進度

綠色打勾是已完成，藍色是目前步驟。點任一個圓點，下方會說明這一步還差什麼，並提供「繼續」或「查看」按鈕。

## 下一步建議的順序

紅 逾期的改善事項、風險與 SoA 衝突 → 藍 待評估、待判定 → 其他提醒。處理完一項，清單會自動換下一項。

**建議的工作節奏**

每次打開工具，先看總覽第 1 項建議；做完回到總覽，再做下一項。不需要記住每個分頁的用途。

展開最下方「進度怎麼判斷」，可以看到每一步的完成條件。

# 確認風險準則，再新增風險

準則要在評鑑風險之前定好（6.1.2 a），不然每個人評分的標準不一樣，分數就沒有意義。




「調整準則」：等級、分數範圍、處理原則，以及各級定義。

1. **選預設組合或自訂等級**
   四級（低／中／高／極高）或三級。每級設定分數上限與處理原則：可接受、需擁有者核准、不可接受。
2. **寫下可能性與衝擊的定義**
   按「填入參考定義」先帶入範例，再改成公司自己的數字，例如「損失小於 10 萬元」「多部門中斷約 1 天」。
3. **按「確認並套用」**
   導入進度第 2 步會打勾。準則內容會匯出到 Excel 的「風險評鑑準則」工作表，請交管理階層核准。

**定義寫清楚的好處**
之後評風險時，選了可能性與衝擊，下方會直接顯示該級的定義，評分的人不用另外翻文件。

## 從常見情境新增風險

1. **風險評鑑 → 「新增風險」**
   輸入關鍵字，或點「離職」「勒索」「釣魚」等常見情境。
2. **挑一個情境按「建立」**
   帶入描述、威脅與建議的控制措施；已登錄過的會標示「已登錄」。
3. **改寫成公司的情況**
   描述寫成「可能發生」的事件；帶入的威脅只是情境範例。

**常見誤會**
風險不是「已經發生的事」。去年真的發生過的事件，請登錄在改善追蹤，並把它當成評估可能性的依據：發生過，可能性就不能評「幾乎不會」。




新增風險：先挑情境，或建立空白風險。

# 評估與處理一個風險

風險詳細頁分成「識別、評估、處理」三段，欄位會依你的選擇出現，只需要填當下用得到的。




① 識別、② 評估：選分數後顯示等級與處理原則。




③ 處理：選「降低」才出現控制措施與殘餘風險。

**1 識別**
描述、相關資產、風險擁有者。威脅、脆弱性、現有控制收在「更多細節」，建議也填，風險評鑑表會用到。

**2 評估**
選可能性與衝擊，分數 = 兩者相乘。

**3 處理方式**
接受：在可接受範圍內，或由擁有者核准承擔。
降低：選控制措施、寫計畫與期限。
移轉：保險、契約或委外。
避免：停止造成風險的活動。

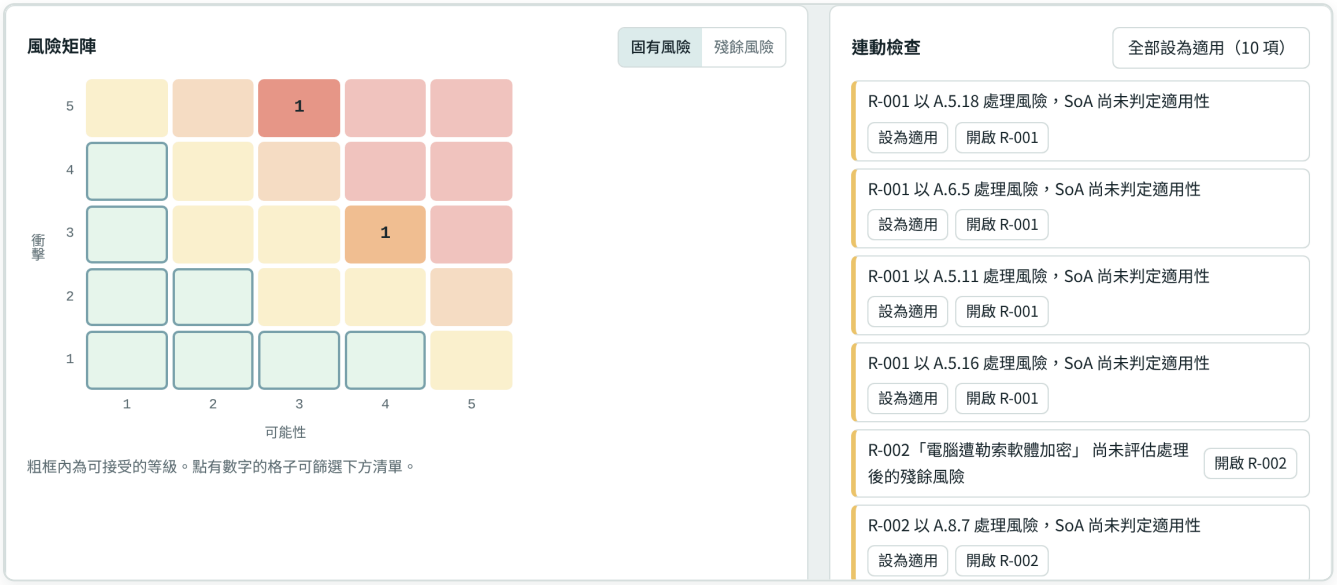
**4 殘餘風險與核准**
評估處理後的分數；若仍屬「需核准」等級，勾選擁有者核准。

## 風險表上的兩個欄位

| 欄位 | 意思 | 常見情況 |
|---|---|---|
| 進度 | 你選的處理狀態：規劃中、處理中、已完成；接受的風險顯示「接受」或「已核准接受」 | 處理計畫做完，改成「已完成」 |
| 檢查 | 與 SoA 的連動檢查結果。「✓ 無問題」或「待確認 N」，滑鼠移上去看原因 | 已完成但殘餘風險仍需核准 → 勾選擁有者核准 |

# 完成適用性聲明（SoA）

風險選定的控制措施就是 SoA「適用」的最好理由。先處理連動檢查，再判定其餘項目。




風險評鑑：右側連動檢查列出風險用到、但 SoA 還沒判定的控制措施；「全部設為適用」會一次設定並補上理由，可以復原。




附錄 A 確認：從下一步建議點進來會自動篩選「未決定」的項目。上方的生命週期檢視預設收合，需要時再展開。

1. **連動檢查 →「全部設為適用」**
   理由自動填「依風險評鑑結果」。
2. **判定其餘控制措施**
   每項選適用或不適用，並選理由：風險評鑑結果、法律法規、契約要求、營運需求與最佳實務。
3. **不適用一定要寫理由**
   沒寫會以紅框標示，這是稽核最常開的缺失之一。
4. **填執行狀態、負責人、證據位置**
   證據位置欄的灰字是常見證據參考。

**產業建議重點**

有紫色底線的是依產業與業務特性建議優先關注的項目，只是提示，不會替你判定。點項目可看說明、相關案例與文件範本。

# 文件、核准、稽核與改善

## 文件範本與條款 4–10

「文件範本」分頁依五層架構提供 32 份範本，上方表格列出條款 4–10 一定要保存的文件化資訊。黃色【】的地方改成公司內容即可；也可以一次下載 ZIP。

「條款 4–10」逐條記錄執行狀態與證據位置。條款 4.1 記得判斷氣候變遷是否為相關議題（Amd 1:2024），POL-03 範本已附表格。

## 核准與匯出

1. **專案管理 → 文件管制資訊**
   填文件編號、版次、編製、審查、核准；核准後狀態改為「已核准」。這些資訊會印在 Excel 每個工作表的表頭。
2. **匯出 SoA Excel**
   包含 SoA、風險登錄表、風險評鑑準則、連動檢查、改善追蹤、條款檢核、統計摘要與修改紀錄。
3. **匯出專案檔（JSON）備份**
   換電腦時匯入即可繼續。




改善事項：不符合事項依 10.2 填寫。

## 內部稽核之後：改善追蹤




改善追蹤：未結案、逾期、待確認有效一目了然；分頁上方的「這個分頁怎麼用」說明各類型對應的條款。

| 類型 | 要填 |
| --- | --- |
| 不符合事項（10.2） | 立即處置、原因分析、矯正措施；完成後確認有效才結案 |
| 觀察事項、資安事件檢討 | 處理措施；建議填原因分析 |
| 管理審查決議、改善機會 | 處理措施、負責人、完成日期 |

# 從 Excel 匯入，找出缺口

已經用 Excel 做過 SoA 或風險評鑑表的話，不必重新輸入。匯入後工具會檢查兩者是否一致，並告訴你還缺什麼。

1. **首頁 →「從 Excel 匯入」**
   選 .xlsx 檔。匯入會建立新專案，原本的專案不受影響。
2. **看匯入報告**
   列出讀到的工作表、控制措施與風險數、是否讀到風險準則，以及略過的列與原因。
3. **回到總覽，照下一步建議補齊**
   常見的是：補不適用理由、確認風險準則、寫可能性與衝擊定義、指定負責人。
4. **再匯出**
   得到含文件管制表頭、連動檢查的完整 Excel。




匯入報告：讀了哪些工作表、各幾筆，以及連動檢查結果。

## 工具怎麼認你的欄位

依「欄位名稱」辨識，不看欄位順序。以下寫法都認得：

| 資料 | 可辨識的欄名（例） |
|---|---|
| 控制措施 | 控制措施編號、控制編號；A.5.16／18 這類合併寫法會自動拆開 |
| 適用性 | 適用性、是否適用；值可寫適用／不適用、是／否、Y／N |
| 理由 | 納入或排除理由、選擇理由；代碼 RA、LR、CO、BP |
| 狀態 | 執行狀態、實施狀態；規劃中、建置中、待驗證等常見說法 |
| 風險 | 風險編號（R-001）加上描述、資產、威脅、可能性、衝擊等至少兩欄 |
| 準則 | 「風險等級／分數上限／處理原則」表，或「高風險｜R 15~25：須處理」這類文字 |

# 匯入後最常見的缺口

這些是 Excel 自己做的 SoA 最常被稽核員追問的地方，也是匯入後下一步建議最常出現的項目。

| 下一步建議 | 為什麼重要 | 在哪裡處理 |
| --- | --- | --- |
| 處理風險與 SoA 的衝突 | 風險用某項控制措施處理，SoA 卻寫不適用，兩份文件互相矛盾 | 風險評鑑 → 連動檢查 |
| 補填排除理由 | 標不適用卻沒寫理由，是最常見的缺失 | 附錄 A（自動篩選） |
| 確認風險評鑑準則 | Excel 沒有準則表時會帶入預設值，需要確認 | 風險評鑑 → 調整準則 |
| 寫可能性與衝擊定義 | 沒有定義，不同人評分無法一致 | 調整準則 → 定義表 |
| 取得殘餘風險核准 | 處理後仍屬需核准等級，要有擁有者核准紀錄（6.1.3 f） | 風險詳細頁 → 處理段 |
| 指定負責人 | 每項控制措施都要有人負責（5.3） | 附錄 A |

## 還沒有 Excel？用範本開始

「文件範本」分頁的「SoA＋REC-02」是空白活頁簿，另有虛構公司的「填寫範例」。在 Excel 填好後，用「從 Excel 匯入」檢查。

## 匯入本工具匯出的 Excel

會保留專案名稱、產業與業務特性、文件管制資訊、風險準則與定義、改善追蹤。適合把 Excel 寄給同事填寫後再匯回來。

**公司的真實資料**

匯入只在你的瀏覽器裡處理，不會上傳。但匯出的專案檔與 Excel 含有公司資訊，存放與分享時請依公司的資料分級規定。

不是有效的 Excel、或找不到「控制措施編號」「風險編號」欄位時，畫面會說明原因；略過的項目也會列在匯入報告。修正 Excel 後再匯入即可。

# 每年一次：建立新年度

ISMS 每年要重新評估風險、更新 SoA、做內部稽核與管理審查。以去年的專案為基礎建立今年的版本，原專案保持不變。




專案管理 → 年度循環 →「建立新年度」。

## 建立時會自動處理

- 保留適用性、理由、實施方式、負責人與風險內容
- 「已驗證」改回「已實施」，提醒重新收集今年的證據
- 風險保留去年分數並標示「待重新評估」；擁有者核准要重新取得
- 未結案的改善事項帶入新年度，已結案的留在去年紀錄
- 文件版次加一（1.0 → 2.0）、日期清空、狀態改回草案
- 保存去年的快照，修改紀錄從新年度開始

## 建立後的工作

1. **總覽的下一步建議**
   通常是「重新評估 N 項風險」與「核准 SoA」。
2. **逐一確認風險**
   依今年情況調整分數，或按「已重新評估」。今年發生過的事件要反映在可能性。
3. **重新收集證據**
   確認後把控制措施改回「已驗證」。

**新增的要求別漏掉**
條款 4.1 要判斷氣候變遷是否為相關議題（Amd 1:2024），每年更新組織全景分析時一併檢視。

# 與去年比較，準備管理審查




年度比較：摘要、前次改善事項、適用性與狀態變化、風險變更、處理計畫追蹤。

1. **專案管理 →「與去年比較」**
   比較基準可選建立新年度時保存的快照，或任何一個專案（例如去年用 Excel 匯入的）。
2. **匯出比較 Excel**
   附在管理審查會議紀錄。

| 管理審查輸入（9.3.2） | 比較 Excel |
|---|---|
| a) 前次決議處理情形 | 前次改善事項 |
| d) 資安績效 | 摘要、實施狀態變化 |
| f) 風險評鑑與處理計畫狀態 | 風險變更、處理計畫追蹤 |
| b、c、e、g 其他輸入 | 需另行準備 |

## 多專案與顧問使用

- **一家公司或一次驗證一個專案**，頁首的專案選單切換；名稱可含年份，建立新年度時會自動加一。
- **專案檔交接**：匯出 JSON 給同事，對方匯入後可繼續；Excel 給不使用工具的人填寫後再匯回。
- **案例搜尋當查詢工具**：主管或同事問「員工帶筆電回家要注意什麼」，輸入日常說法就能找到條款與應留紀錄。
- **自訂案例**：把公司特有的系統或流程存成情境範本，搜尋與新增風險時都能挑選。

**備份習慣**
資料存在瀏覽器裡。每次重要修改後匯出專案檔；「專案管理」的備份狀態會顯示上次匯出時間與之後的修改筆數。

# 想做什麼，去哪裡

| 我想… | 去哪裡 |
| --- | --- |
| 知道現在該做什麼 | 總覽 → 下一步建議 |
| 查某個工作情境對應哪些條款 | 案例搜尋，輸入日常說法 |
| 新增或評估風險 | 風險評鑑 → 新增風險 |
| 修改風險準則或可能性、衝擊定義 | 風險評鑑 → 調整準則 |
| 判定控制措施適用性、填理由與證據 | 附錄 A 確認 |
| 登錄稽核發現、管理審查決議 | 改善追蹤 → 新增改善事項 |
| 下載政策、程序、表單範本 | 文件範本 |
| 匯出 SoA 與風險評鑑表 Excel | 專案管理 → 匯出 SoA Excel |
| 換電腦繼續用、交接給同事 | 專案管理 → 匯出專案檔（JSON）／匯入專案檔 |
| 開始新的年度、與去年比較 | 專案管理 → 年度循環 |

## 驗證稽核前檢查清單

- ☐ 驗證範圍寫成一句完整的話
- ☐ 條款 4.1 已判斷氣候變遷是否相關，並留紀錄
- ☐ 風險準則與各級定義已經管理階層核准
- ☐ 每個風險都有擁有者、分數與處理方式
- ☐ 需核准的殘餘風險都有擁有者核准
- ☐ 風險選定的控制措施在 SoA 都是適用
- ☐ 不適用的控制措施都有排除理由
- ☐ 適用的控制措施都有負責人與證據位置
- ☐ SoA 文件管制狀態為「已核准」
- ☐ 條款 4–10 要求的文件化資訊都已建立
- ☐ 已完成內部稽核與管理審查
- ☐ 不符合事項都已原因分析並確認有效
- ☐ 已匯出最新的專案檔與 SoA Excel 備份
- ☐ 總覽導入進度 8／8，下一步建議已清空

## 常見問題

| | |
| --- | --- |
| **工具判定「完成」就代表會通過稽核嗎？** | 不會。導入進度只是依資料判斷的提示；是否符合標準由稽核員依證據判斷。 |
| **處理狀態選了「已完成」，檢查欄還是「待確認」？** | 兩者不同：檢查欄是連動檢查。滑鼠移上去看原因，常見是殘餘風險還需要擁有者核准。 |
| **清除瀏覽資料後專案不見了？** | 資料只存在瀏覽器。請用之前匯出的專案檔（JSON）在「專案管理」匯入。 |
| **範例裡的修改會保存嗎？** | 不會。想保留請按「以此範例建立我的專案」。 |

條款名稱與說明為工具自行撰寫的摘要，不含 ISO/IEC 27001 標準原文；正式內容請參照取得授權的標準文件。範例中的公司、人員與系統皆為虛構。